

Plano de Resposta a Incidentes de Segurança — Mentto

Versão: 1.0
Data: Julho/2026
Aplicável a: Todos os sistemas internos e externos da Mentto
Contato LGPD: lgpd@mentto.com.br

1. Objetivo

Definir os procedimentos mínimos a serem seguidos em caso de incidente de segurança que envolva dados pessoais, garantindo conformidade com o **Art. 48 da LGPD**, que exige comunicação à ANPD e aos titulares afetados em prazo razoável.

2. O que é um Incidente de Segurança?

Qualquer evento que comprometa a **confidencialidade, integridade ou disponibilidade** de dados pessoais, incluindo:

Tipo	Exemplos
Acesso não autorizado	Invasão, credenciais vazadas, acesso indevido por ex-colaborador
Vazamento de dados	Dados expostos publicamente, envio para destinatário errado
Perda ou destruição	Exclusão acidental, falha de backup, ransomware
Alteração indevida	Modificação de registros sem autorização

3. Classificação de Gravidade

Nível	Descrição	Prazo de resposta
Crítico	Dados sensíveis expostos; acesso não autorizado confirmado; vazamento público	Imediato — até 2 dias úteis para notificar ANPD
Moderado	Suspeita de acesso indevido; incidente contido mas com risco residual	Até 5 dias úteis
Baixo	Erro interno sem exposição externa; dado de um único titular; sem risco significativo	Até 10 dias úteis; registrar internamente

4. Passo a Passo de Resposta

Etapa 1 — Identificar e Conter (Dia 0)

- Identificar o incidente: anotar data, hora e sistema afetado.
- Isolar o sistema comprometido (desabilitar acesso, revogar tokens, trocar credenciais).
- Preservar evidências (logs, prints, registros) — não deletar nada durante a apuração.

- Avisar imediatamente o responsável de TI e o contato LGPD (lgpd@mentto.com.br).

Etapa 2 — Avaliar o Impacto (Dias 1–2)

Responder às seguintes perguntas:

- Quais dados foram afetados? (nome, e-mail, senha, dados financeiros etc.)
- Quantos titulares foram impactados?
- Os dados eram sensíveis (Art. 5º, II da LGPD)?
- O incidente foi contido ou ainda está ativo?
- Há risco real de dano aos titulares (discriminação, fraude, dano financeiro)?

Etapa 3 — Notificar (conforme gravidade)

Se o incidente for Crítico ou Moderado com risco real:

1. **Notificar a ANPD** pelo portal gov.br/anpd, opção "Comunicação de Incidente".
 - Prazo recomendado: até 2 dias úteis após a confirmação (Art. 48 da LGPD).
 - Informar: natureza do incidente, dados afetados, número de titulares, medidas adotadas.
2. **Notificar os titulares afetados** por e-mail ou comunicado interno:
 - Descrever o que aconteceu (sem expor detalhes técnicos sensíveis).
 - Informar quais dados foram afetados.
 - Orientar ações que o titular pode tomar (trocar senha, monitorar e-mail etc.).
 - Informar canal de contato: lgpd@mentto.com.br.

Se o incidente for Baixo:

- Registrar internamente (ver Etapa 4) — notificação externa não é obrigatória.

Etapa 4 — Corrigir e Registrar

- Corrigir a vulnerabilidade que causou o incidente.
- Documentar internamente:
 - Data e hora do incidente
 - Sistema afetado
 - Dados e titulares impactados
 - Causa raiz identificada
 - Medidas corretivas adotadas
 - Se houve notificação à ANPD e/ou titulares, e quando
- Arquivar o registro por **mínimo de 5 anos**.

5. Contatos de Referência

Papel	Contato
Contato LGPD interno	lgpd@mentto.com.br
Portal de notificação da ANPD	gov.br/anpd
Formulário de incidente ANPD	gov.br/anpd — Servicos — Comunicação de Incidente

6. Revisão

Este documento deve ser revisado **anualmente** ou sempre que:

- Um novo sistema for colocado em produção
- Ocorrer um incidente real
- Houver mudança na legislação aplicável